

What We Fixed in Root

A plain-English summary of the security and quality check, September 27, 2026

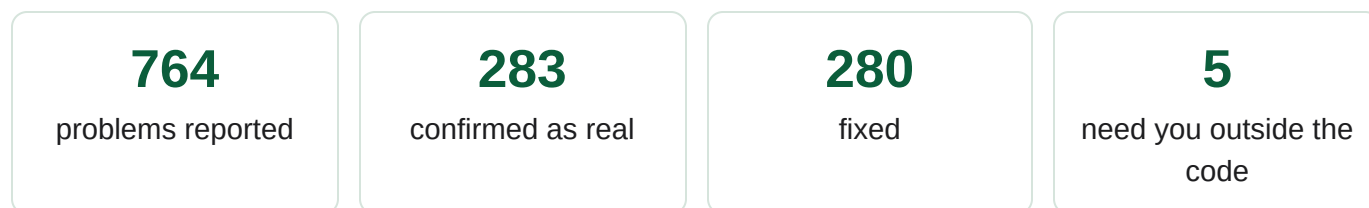
What happened

Root is the website and app that sells marketing to home-service businesses, like plumbers and roofers. Before more customers sign up, we wanted to find everything that could go wrong.

So we ran a "red team." Think of it as hiring 150 expert critics to attack the product on purpose. Each critic had one specialty (security, payments, the customer's experience, the law, and so on) and looked at one part of the product (sign-in, billing, emails, the owner's dashboard, and so on).

Every serious problem they reported was then double-checked by two separate reviewers. A problem only counted if both reviewers agreed it was real. That stops false alarms from wasting time.

The results in numbers



All fixes were checked by the project's automatic tests before being saved: **4,898 tests passed**, plus 26 tests that run in a real web browser, and the full website build. Nothing was deleted from the site. Of the 8 problems where the two reviewers disagreed, 6 were real and fixed, and 2 were already fixed.

How serious were they?

Level	What it means	How many were confirmed
Critical	Could lose money, leak private info, or lock a customer out	10 (all fixed)
High	Something breaks, a number is wrong, or a customer would complain	117
Medium	Confusing, slow, or fragile	153
Low	Small polish	3

The 10 Most Serious Fixes

Each one: what was broken, what could have happened, and what we changed.

- 1. Removing an employee didn't remove their access.** If a fired worker had ever clicked anything, deleting them failed with a confusing error, so they could still log in. Now removing someone works and their access ends.
- 2. An old email link could change someone else's password.** On a shared computer, opening an expired sign-up link could reset the password of whoever was already logged in. Now the link only works for its real owner.
- 3. The demo showed a real customer's business to strangers.** Anyone who signed up after watching the demo got linked to a real client's account and saw their reports. The demo is now kept separate from real customers.
- 4. A business name could sneak code onto a web page.** A name typed in a sneaky way could run a script on the customer's draft website. Names are now cleaned before they are shown.
- 5. A paused order kept charging the card.** When a payment was set aside for a manual check, the monthly charge kept going. Now the charge is stopped too.
- 6. People who said "don't email me" could still get emails.** Importing an email list ignored the "no" column. Now anyone who said no is left out.
- 7. The AI helper never answered.** A typo in how it counted daily questions made it refuse every time. It works now.
- 8. Two dashboard tabs crashed.** As soon as any customer's task was running late, the owner's Business and Delivery tabs broke. They load now.
- 9. The dashboard mixed up customers.** Clicking from one customer to another could still show the first customer's details. Each customer now shows only their own info.
- 10. Quote requests were thrown away.** A customer's website form silently dropped every quote request after the 3rd of the day, which means lost jobs. The limit now applies to spammers, not real customers.

Everything Else, and What's Left

Fixes by part of the product

Area	Fixed	Examples in plain words
Owner's dashboard	46	Correct numbers, lists no longer cut off at 1,000, faster loading
Delivering the work	39	Approvals, previews and review requests behave correctly
Free audit report	36	Honest results, safer share links
Getting started	30	Uploads, setup steps and booking calls work reliably
Emails and texts	29	Respect "stop" and "unsubscribe," no double sends
Automatic jobs	25	Scheduled tasks don't skip or run twice
Billing	21	No double charges, correct prices and trial rules
Database	15	Data stays consistent when things happen at the same time
Sign-in	14	Safer passwords, invites and sessions
Marketing website	8	Contact form and pages work as promised

Choices we made for you (you can change any of them)

- **Two-step login for Root admins** is on for anyone who turns it on. One setting makes it required for everyone, so nobody gets locked out.
- **Seeing a customer's saved password** now needs a fresh two-step code, and is limited to 30 times an hour.
- **After a customer cancels**, their saved logins and app connections are removed after 30 days.
- **Review texts** only go out 9am to 8pm in the customer's time zone. **Failed payments** pause the work after 7 days.

Things only you can do (5)

- Register each customer's texting number with the phone carriers, and set up a separate email sender for customer campaigns. Step-by-step guides are in the project.

Before going live

- Apply the new database updates by hand in Supabase, in number order (starting at 0051). Some are required first.
- Review the changes on the **redteam/fixes** branch, then merge it into the main site.
- Set up the free outside scheduler (cron-job.org) for the two 30-minute checks. Steps are in the handoff guide.

Source: Root red team audit and fix run, repository CottonQb/hshc, branch redteam/fixes, September 27, 2026.